

1. Identify three major stages of Mitnick's IP spoofing attack and the purpose of each.
 - a. Mitnick used commands such as `finger`, `showmount`, and `rpcinfo` to find trust relationships between each host. The services that are trusted on the UNIX systems could then later be exploited.
 - b. Mitnick then flooded the TCP Connection queue with SYN-ACK requests so that it could not respond. This made sure that reset packets could not be sent.
 - c. Lastly Mitnick used TCP sequence number prediction, and forged packets that appeared to come from the trusted host. He was later able to gain root access.
2. Explain how **trust relationships** (e.g., `.rhosts`, `rlogin`) enabled the intrusion.
 - a. IP Address based trust was implemented meaning that the attacker impersonated the trusted host's IP, so when the target saw a login request from that IP, the service accepted it as authenticated. `.rhosts` stored the 'trusted' IP's that `rlogin` used to allow passwordless authentication.
3. Why was **TCP sequence number prediction** essential?
 - a. It is essential because TCP is reliable and needed a correctly sequenced ACK in order to be accepted. However, since the target used predictable sequencing, the packets were able to be forged.
4. What was the function of the **SYN flooding** step?
 - a. SYN flooding flooded the TCP Connection queue so that the trusted host would be silenced, ensuring RST Packets could not be sent and interrupt the attack.
5. Why did **r-services** make this attack easier compared to modern auth?
 - a. R-services made this attack so easy because they authenticate solely based on the IP & no password was required (nor cryptographic key).
6. List two weaknesses in the original TCP/IP design exploited in this case.
 - a. TCP ISN's were easy to predict
 - b. No authentication
7. 1994 perspective: what **defenses/detections** could admins have used? What modern controls map to them?
 - a. Disable r-services (and any passwordless login)
 - b. Log and monitor incoming packets
8. Was this more about technical skill or exploiting trust? Defend your view.
 - a. Although deep knowledge was needed of networks at a low-level, I would say this is more about exploiting trust. The entire attack was dependent on the target trusting connections (address-based auth, `.rhosts`, privileged port conventions, predictable ISNs). Without this, the attack could have never happened.

9. Should protocols “trust” or “verify”? Discuss the ethics of trust-based auth.
 - a. Protocols should only trust when absolutely necessary, otherwise verification should be required. It is not responsible for trust to be granted on weak authentication (such as IP values).
10. How would incident response **today** differ from 1995?
 - a. Response would differ heavily from 1995. There would be enhanced logging, containment, and the ability to restart services that are crucial. Furthermore, entries in .rhosts would be cleared and systems rely on verification rather than trust.
11. Draft a 3-step **incident response plan** for spoofing at a university network (historical constraints).
 - a. **DETECT/CONTAIN:** I would set up logging for all requests and employ simple methods to detect anomalies. I would also block incoming traffic to service ports (such as, port 513) from suspicious networks and block obvious spoofed source addresses.
 - b. **RECOVERY:** In the event of a successful attack, I would cut the systems off from the network to prevent further damage. I would then reinstall / swap out any trust-based keys (.rhosts) and reboot systems.
 - c. **PREVENTION:** I would then in the coming days and beyond, implement stricter security measures and ensure that a full analysis of the attack is performed. I would migrate from a trust-based system to a verification-based system.
12. Which link in the attack chain should be **prioritized for prevention**, and why?
 - a. I would prioritize removing IP-based trust. If a host does not allow passwordless authentication, then a successful IP-spoof alone cannot grant access. Fixing this link breaks the chain at the earliest step and is straightforward.